

AI Audit Report - HW06-AI API Testing on EShop

Student: Ong Khánh Vinh

MSSV: 23127522

Class: 23KTPM1

Selected features: FR04 - Profile Management, FR09 - Apply Coupon, FR17 - Coupon Administration

System under test: eshop-sut backend Node.js/Express + SQLite, chạy local tại `http://localhost:3000`

Automation stack: Postman, Newman, HTMLEXTRA, SQLite và GitHub Actions

Main AI tool: Codex CLI với provider do sinh viên cấu hình

Report date: 25 August 2026

Repository: [venncoder08/HW06_API_Testing](#)

Detailed interaction log: `docs/AI_Interaction_Log.md`

Declaration

- ☐ I do not use any AI help in this exercise.
- ☒ I use AI tools for the following tasks.

Tôi sử dụng AI để hỗ trợ đọc requirement và API specification, giải thích thuật ngữ kiểm thử, thiết kế testcase, sinh Postman/Newman artifacts, chuẩn bị fixture SQLite, tổng hợp kết quả, tạo bảng chứng lỗi, hỗ trợ CI/CD, tạo agent skill và soạn tài liệu. Tôi không xem output của AI là kết luận cuối cùng. Tất cả 197 testcase đã được sinh viên review; kết quả được đối chiếu với specification, Newman report, dữ liệu chạy lại có kiểm soát, GitHub Actions và GitHub Issues trước khi ghi vào Excel và báo cáo.

Scope Of AI Use

Nhóm công việc	AI hỗ trợ	Evidence dùng để kiểm chứng
Hiểu đề và khởi tạo	Giải thích thuật ngữ API testing, Newman, Postman environment, schema, boundary, equivalence partition, state và security testing.	<code>guide.md</code> , yêu cầu bài tập và source tree của repository
Chọn phạm vi	Ban đầu phân tích FRO2/FRO9/FR17, sau đó cập nhật theo quyết định đổi FRO2 thành FRO4.	<code>test-plans/FR04.md</code> , <code>test-plans/FR09.md</code> , <code>test-plans/FR17.md</code>
Phân tích requirement	Đọc README, API specification và backend để xác định endpoint, input partitions, authentication, authorization, state, calculation và schema oracle.	<code>eshop-sut/README.md</code> , <code>eshop-sut/api_specification.md</code> , <code>eshop-sut/backend/server.js</code> , <code>eshop-sut/backend/database.js</code>
Sinh testcase	Tạo tối thiểu 35 testcase cho mỗi feature và gán loại như Positive, Negative, Boundary, Security, State, Schema và Data Integrity.	Ba test plan và ba workbook trong <code>test-cases/</code>
Sinh Postman/Newman	Tạo collection, environment, data-driven JSON, pre-request/test scripts và lệnh chạy Newman.	<code>hw06-api-tests/postman/</code> , <code>hw06-api-tests/package.json</code>
Student header	Gán <code>X-Student-Id: 23127522</code> bằng collection-level pre-request script.	Postman collections, Newman console logs và <code>issues/NEWMAN-CONSOLE-EVIDENCE.md</code>
Troubleshooting	Sửa lỗi token, <code>baseUrl</code> , cách chọn folder/data file, báo cáo <code>No tests found</code> , và việc hiểu sai request hiển thị trong Postman UI.	Collections/data files đã sinh lại và sáu Newman HTML reports
Audit và execution	Tách đánh giá chất lượng testcase khỏi kết quả chạy; thêm Actual Result, Execution Status, Bug ID, Evidence và Summary sheet.	<code>test-cases/audit-overrides.json</code> , ba workbook Excel, <code>test-cases/README.md</code>
Fixture và rerun	Chuẩn bị trạng thái SQLite cho các case phụ thuộc dữ liệu, chạy lại và khôi phục seed mặc định.	<code>hw06-api-tests/scripts/run-prepared-cases.mjs</code> , <code>hw06-api-tests/reports/newman/prepared/</code>

Nhóm công việc	AI hỗ trợ	Evidence dùng để kiểm chứng
Defect reporting	Chọn tám lỗi đại diện, tạo nội dung issue và bắt `ng chứng Newman CLI.	GitHub Issues #1-#8, tám PNG trong <code>issues/</code> , raw logs trong <code>reports/newman/console-issues/</code>
CI/CD	Tạo GitHub Actions workflow, green/red/recovery demonstration và báo cáo CI/CD.	<code>.github/workflows/api-tests.yml</code> , <code>docs/CI-CD-REPORT.md</code> , ba Actions runs
Tài liệu tái sử dụng	Tạo agent skill, sơ đồ `pseudocode AI test generator và Main Report.	<code>agent-skills/hw06-api-testing/</code> , <code>docs/ai-test-generator.*</code> , Main Report Markdown/PDF

AI Interaction Log Summary

Bảng này tóm tắt các cụm tương tác chính. Nhật ký chi tiết trong docs/AI_Interaction_Log.md được trích trực tiếp từ Codex session JSONL, sử dụng timestamp thật theo Asia/Saigon, prompt thật và verbatim excerpt của final output. Không có timestamp hoặc tương tác nào được tự dựng.

#	Yêu cầu / quyết định của sinh viên	AI output hoặc thay đổi	Human review và correction
1	Đọc HW06 API Testing và đề xuất phần cần khởi tạo cho FR02, FR09, FR17.	Đề xuất source tree, guide và cách tách Newman khỏi SUT.	Sinh viên đổi phạm vi từ FR02 sang FR04.
2	Giải thích toàn bộ thuật ngữ testing trước khi bắt đầu.	Soạn nội dung hướng dẫn trong guide.md .	Sinh viên hỏi lại cách chứng minh x-Student-Id và xác nhận API test không cần console.log thủ công.
3	Phân tích EShop và sinh ít nhất 35 testcase mỗi feature.	Sinh plans bao phủ partition, boundary, schema, security và state phù hợp.	Sinh viên yêu cầu bỏ FR10 và standalone SEC labels vì không thuộc ba task đã chọn.
4	Review và sửa ba plans.	Chỉnh testcase theo requirement/specification đã đọc.	Sinh viên duyệt plans trước khi tạo automation.
5	Sinh bộ Newman để review trước khi chạy.	Tạo collections, environment và sáu data files.	Sinh viên phát hiện token/base URL/folder mapping chưa đúng ở một số case; AI sinh lại.
6	Tạo test-cases , phân loại Type và xuất Excel.	Tạo testcase records và workbook.	Sinh viên yêu cầu reset Audit, thêm Note, bỏ Automation/AI-generated và tách thành ba file Excel.
7	Kiểm tra reports và phân loại kết quả.	Tổng hợp kết quả Newman theo iteration.	Sinh viên sửa cách hiểu VALID/INCOMPLETE ; Audit được tách khỏi PASS/FAIL/BLOCKED.
8	Giải thích vì sao FR04 PUT có nhiều failure.	Truy vết assertion Verify User Profile và phát hiện password/reset token bị lộ.	Không kết luận mọi expected result đều sai chỉ vì một assertion bảo mật dùng chung bị fail.
9	Chuẩn bị database và chạy lại các case blocked.	Tạo fixture riêng, rerun chín case và khôi phục database.	Kiểm tra lại coupon IDs, usage state và default profile; kết quả cuối còn o BLOCKED.

#	Yêu cầu / quyết định của sinh viên	AI output hoặc thay đổi	Human review và correction
10	Tích hợp GitHub Actions và tạo green/red evidence.	Tạo workflow, CI subset, report và hướng dẫn commit.	Sửa lỗi npm ci do SUT thiếu lockfile tại đường dẫn cũ; công khai rằng green run dùng 19 iterations.
11	Tạo GitHub Issues và ảnh bằng chứng.	Tạo tám issue và ảnh từ report.	Sinh viên yêu cầu thay/bổ sung ảnh Newman console thật; tám CLI screenshots được tạo và mapping lại.
12	Đóng gói agent skill, Main Report và AI generator.	Tạo skill, Mermaid, PNG, pseudocode, Markdown và PDF.	Sinh viên xác nhận đã review 197 AI-generated cases và duyệt flow trước khi convert Mermaid.

Evidence Used For Final Conclusions

Feature	Design evidence	Automation evidence	Execution evidence	Final Excel
FR04	test-plans/FR04.md	HW06-FR04.postman_collection.json , fr04-get.json , fr04-put.json	FR04-GET.html , FR04-PUT.html	test-cases/FR04-Test-Cases.xlsx
FR09	test-plans/FR09.md	HW06-FR09.postman_collection.json , fr09-apply.json	FR09-APPLY.html , prepared-case reports	test-cases/FR09-Test-Cases.xlsx
FR17	test-plans/FR17.md	HW06-FR17.postman_collection.json , fr17-get.json , fr17-create.json , fr17-delete.json	FR17-GET.html , FR17-CREATE.html , FR17-DELETE.html , prepared-case reports	test-cases/FR17-Test-Cases.xlsx

Các đường dẫn automation và report trong bảng nằm dưới `hw06-api-tests/postman/` và `hw06-api-tests/reports/newman/`. Bảng chứng chỉ tiết của tám defect nằm trong `issues/NEWMAN-CONSOLE-EVIDENCE.md`.

Final Execution Summary

Suite	Testcases	Audit VALID	PASS	FAIL	BLOCKED
FR04	50	50	7	43	0
FR09	58	58	33	25	0
FR17	89	89	40	49	0
Total	197	197	80	117	0

Audit: VALID nghĩa là testcase có cơ sở và oracle có thể review. **Execution Status: FAIL** nghĩa là ít nhất một assertion không đạt expected result. Vì vậy một testcase **VALID** vẫn có thể **FAIL** và phát hiện defect của SUT.

Human Review And Corrections

Điểm AI hoặc người dùng từng dễ hiểu sai	Kiểm chứng bằng evidence thật	Kết luận sau review
Ví dụ FR10 và SEC-01 đến SEC-07 trong đề phải trở thành scope riêng.	Ba task cuối cùng là FRO4, FRO9 và FR17.	Chỉ giữ state/security testcase có liên quan trực tiếp tới ba feature; bỏ FR10 và standalone SEC labels.
Newman bắt buộc phải nằm trong eshop-sut .	Newman chỉ cần collection, environment, data và URL tới SUT.	Automation được tách tại hw06-api-tests/ ; SUT vẫn là service độc lập.
Import Newman JSON vào Postman sẽ tự biết environment và token.	Một số request từng giữ {{baseUrl}} chưa resolve hoặc chưa có token đúng.	Phải import/apply environment và dùng login/pre-request flow rõ ràng.
Postman hiển thị POST bên trong folder GET nghĩa là method bị đổi.	Folder chứa setup/login request và request chính; tên folder không ép method của mọi item.	Review method ở từng request thay vì suy luận từ tên folder.
No tests found nghĩa là API không chạy.	Có request chỉ chạy setup hoặc chọn sai folder/data mapping nên không có assertion tương ứng.	Kiểm tra đúng collection, folder, environment và data file trước khi kết luận.
VALID tương đương PASS và INCOMPLETE tương đương FAIL.	Audit đánh giá thiết kế; execution đánh giá lần chạy.	Tách Audit , Actual Result , Execution Status , Bug ID và Evidence .
FRO4 PUT fail hàng loạt nghĩa là mọi input PUT đều bị xử lý sai.	Assertion dùng chung phát hiện response lộ password , làm nhiều iterations fail dù field đang kiểm thử có thể đúng.	Ghi failure bảo mật thật nhưng không gán cùng một nguyên nhân nghiệp vụ cho mọi case.
Case phụ thuộc state bị fail có thể kết luận ngay là backend bug.	Chín case thiếu fixture ổn định cần chuẩn bị database riêng.	Rerun với fixture, lưu evidence và khôi phục seed; chỉ kết luận sau khi state được kiểm soát.
Green CI chứng minh toàn bộ 197 testcase pass.	Workflow xanh chạy deterministic subset gồm 19 iterations.	Công khai CI scope; full suite có 80 PASS và 117 FAIL do các defect/vi phạm specification hiện hữu.
Ảnh HTML report là đủ để gọi là Newman console evidence.	Sinh viên yêu cầu bằng chứng trực tiếp từ CLI.	Tạo tám console screenshots, mỗi ảnh có X-Student-Id , localhost request, assertion failure và exit code 1 .

Bug And API Issues Reported

Issue	Feature	Defect	Evidence
#1	FR04	GET/PUT profile exposes password	FR04-TC-009 console evidence
#2	FR04	PUT profile accepts an invalid short phone	FR04-TC-020 console evidence
#3	FR09	Percentage coupon returns incorrect amounts	FR09-TC-001 console evidence
#4	FR17	Regular user can list coupons	FR17-TC-003 console evidence
#5	FR17	Duplicate coupon code returns HTTP 500	FR17-TC-020 console evidence
#6	FR17	Regular user can delete a coupon	FR17-TC-078 console evidence
#7	FR04	Basic authorization scheme is accepted	FR04-TC-007 console evidence
#8	FR04	GET profile exposes reset_token	FR04-TC-010 console evidence

CI/CD Evidence

Demonstration	Commit / run	Result	Interpretation
Green	Commit <code>e4c5f916</code> , run <code>32733160221</code>	Success	Tất cả 19 deterministic CI iterations pass.
Red	Commit <code>b3a3c6c</code> , run <code>32742769020</code>	Failure	Một expected status trong CI-only data được đổi có chủ ý để chứng minh pipeline phát hiện failure.
Recovery	Commit <code>e4b5f3a</code> , run <code>32743294527</code>	Success	Khôi phục expected status và đưa default branch về` xanh.

AI-Generated Artifacts And Disclosure

Artifact	Mức AI tham gia	Human action
197 testcase designs	AI sinh và chỉnh sửa theo nhiều vòng	Sinh viên xác nhận đã review toàn bộ testcase.
Postman/Newman automation	AI sinh code và sửa sau các lỗi thực tế	Sinh viên import vào Postman, chạy Newman và phản hồi các lỗi token/environment/report.
Excel workbooks	AI tổng hợp từ plans và execution evidence	Sinh viên yêu cầu sửa semantics Audit và cấu trúc cột.
AI test generator diagram	AI chuyển flow đã được sinh viên duyệt sang Mermaid/PNG	Phải disclosure vì đề có thể diễn giải nghiêm ngặt yêu cầu self-drawn.
GitHub Issues	AI chuẩn hóa nội dung và bảng chứng	Sinh viên yêu cầu upload và bổ sung Newman console screenshots.
Agent skill và reports	AI soạn cấu trúc, nội dung và PDF	Sinh viên chịu trách nhiệm review trước khi nộp.

Accuracy Safeguards

1. Requirement, API specification và expected result được ưu tiên hơn hành vi hiện tại của backend.
 2. Không dùng một assertion failure chung để suy luận rằng mọi field hoặc mọi partition trong iteration đều sai.
 3. Tách testcase-design audit khỏi execution result trong cả Markdown và Excel.
 4. Case phụ thuộc database state chỉ được kết luận sau khi fixture được chuẩn bị và seed mặc định được khôi phục.
 5. Evidence lỗi phải trỏ tới report/iteration hoặc console log cụ thể; tám issue đại diện có screenshot Newman CLI thật.
 6. Không tuyên bố pipeline xanh chạy toàn bộ 197 cases; CI subset 19 iterations và full diagnostic suite được báo cáo riêng.
 7. Không tuyên bố dùng Postman Monitor, mock server hoặc tính năng không có artifact chứng minh.
 8. Không gán công việc do AI thực hiện thành công việc hoàn toàn thủ công của sinh viên.
-

AI Critique (200-300 words)

AI giúp rút ngắn thời gian đọc requirement, phân tích API và mở rộng độ phủ testcase cho FR04, FR09 và FR17. Công cụ hữu ích khi biến các quy tắc rời rạc thành nhóm equivalence partition, boundary, security, state và schema; sau đó chuyển chúng thành Postman collections, data files, Newman reports và bảng Excel có thể truy vết. AI cũng hỗ trợ tìm nguyên nhân kỹ thuật, chuẩn bị fixture SQLite, xây GitHub Actions và liên kết các failure đại diện với GitHub Issues.

Tuy nhiên, output ban đầu không thể dùng trực tiếp. AI từng mở rộng sai phạm vi sang FR10 và các nhân SEC độc lập, dù ba feature được chọn không bao gồm chúng. Một số collection đầu tiên còn lỗi token, environment và folder mapping. Cách dùng cột Audit cũng từng sai: `VALID` bị hiểu gài như `PASS`, còn `INCOMPLETE` gài như `FAIL`. Với FR04 PUT, assertion bảo mật dùng chung về `password` làm nhiều iteration fail, nên nếu chỉ nhìn tổng số failure sẽ dễ kết luận nhầm rằng mọi input profile đều bị xử lý sai. Các case phụ thuộc state cũng cần fixture thật; nếu không kiểm soát database, AI có thể gán lỗi setup cho backend.

Sau human review, phạm vi được thu hẹp đúng, token và `baseUrl` được sửa, Audit được tách khỏi Execution Status, chín case được chạy lại với database riêng, và tám lỗi có Newman console evidence. Bài học quan trọng nhất là dùng AI như một cộng tác viên có thể kiểm tra, không phải oracle. Mọi kết luận phải truy ngược được tới specification, testcase, iteration, response thực và artifact lưu trong repository; giới hạn như CI chỉ chạy 19 iterations cũng phải được disclosure rõ ràng.